

Réflexion UI/UX — Fonctionnalité *Authentification*

Projet : MediPlan — plateforme de gestion des rendez-vous médicaux **Fonctionnalité analysée** : Authentification et gestion des accès (inscription, connexion, mot de passe oublié, réinitialisation, verrouillage de compte) **Tickets Jira** : MEDIPLAN-15 (s'inscrire et se connecter), MEDIPLAN-16 (réinitialiser le mot de passe et verrouiller le compte), MEDIPLAN-17 (contrôle d'accès RBAC) **Responsable** : Souleymane DIALLO (développée de bout en bout : frontend Angular + backend NestJS)

1. Introduction et présentation des utilisateurs ciblés

L'authentification est la **porte d'entrée** de MediPlan : aucune autre fonctionnalité (prise de rendez-vous, disponibilités, flux clinique) n'est accessible sans passer par elle. Sa qualité conditionne donc la première impression de l'utilisateur et sa capacité à accéder à son espace.

Contrairement aux autres écrans réservés au personnel de la clinique, l'authentification s'adresse à **plusieurs profils** :

- **Le patient** qui crée lui-même son compte (inscription libre-service) et se connecte pour consulter ses rendez-vous ;
- **Le personnel de la clinique** (réception, médecin, administrateur) qui se connecte à un compte déjà provisionné pour accéder à ses outils métier ;
- **Un utilisateur en difficulté** : personne qui a oublié son mot de passe, qui se trompe plusieurs fois, ou dont le compte s'est verrouillé.

Ce document analyse la fonctionnalité **du point de vue d'une personne qui découvre l'application**, sans connaître son fonctionnement interne. On ne se limite pas à décrire l'apparence : on s'intéresse à ce que l'utilisateur **comprend, fait, ressent et rencontre** tout au long de son parcours.

La fonctionnalité se décompose en quatre parcours reliés entre eux :

1. **Créer un compte** (/register)
2. **Se connecter** (/login)
3. **Demander un lien de réinitialisation** (/forgot-password)
4. **Choisir un nouveau mot de passe** (/reset-password?token=...)

Auxquels s'ajoute un état particulier : le **compte temporairement verrouillé** après plusieurs échecs.

2. Analyse par les questions guidées

2.1 Utilisateur et besoin

Qui est l'utilisateur principal ? Toute personne devant accéder à MediPlan — en premier lieu le patient qui s'inscrit, et le membre du personnel qui se connecte quotidiennement.

Quel besoin ou problème cherche-t-il à résoudre ? Obtenir un **accès sécurisé et fiable** à son espace personnel : prouver son identité rapidement, sans friction inutile, et récupérer l'accès s'il a oublié son mot de passe.

Dans quel contexte l'utilisera-t-il ? - Le patient : ponctuellement, souvent depuis un téléphone, dans un contexte de stress léger (prise ou consultation d'un rendez-vous médical). - Le personnel : plusieurs fois par jour, depuis un poste de la clinique, avec une attente de rapidité.

Quel résultat souhaite-t-il obtenir ? Être connecté et redirigé vers son tableau de bord (`/dashboard`) — ou, en cas d'oubli, recevoir un moyen simple de reprendre la main sur son compte.

2.2 Parcours utilisateur

Où commence le parcours ? À la racine de l'application. La route `/` redirige vers `/login` : un visiteur non connecté arrive donc toujours sur l'écran de connexion, point de départ clair et unique. Des **guards** (`guest.guard` , `auth.guard`) empêchent un utilisateur déjà connecté de revoir le login, et un visiteur d'accéder aux pages protégées.

Quelles étapes l'utilisateur doit-il suivre ?

- *Connexion* : saisir e-mail + mot de passe → « Se connecter » → redirection tableau de bord.
- *Inscription* : depuis le login, lien « Créer un compte » → prénom/nom (optionnels), e-mail, mot de passe → « Créer mon compte » → connexion immédiate (le backend renvoie directement un jeton).
- *Mot de passe oublié* : depuis le login, lien « Mot de passe oublié ? » → saisir l'e-mail → message neutre de confirmation.
- *Réinitialisation* : l'utilisateur ouvre le lien reçu (`/reset-password?token=...`) → nouveau mot de passe + confirmation → retour au login.

Sait-il clairement quoi faire à chaque étape ? Oui. Chaque écran porte un **titre explicite** (« Connexion », « Créer un compte », « Mot de passe oublié », « Réinitialiser le mot de passe ») et un **sous-titre** qui reformule l'intention (« Accédez à votre espace de gestion des rendez-vous », « Créez votre compte patient en quelques secondes »). Les champs sont étiquetés sans ambiguïté.

Le nombre d'étapes est-il raisonnable ? Oui. La connexion tient en deux champs ; l'inscription en quatre dont deux optionnels. Le parcours d'oubli/réinitialisation est le minimum incompressible pour une remise à zéro sécurisée (demande → e-mail → nouveau mot de passe).

Comment sait-il que son action a réussi ? - Connexion / inscription réussie : **redirection immédiate** vers le tableau de bord (signal fort et implicite). - Demande de réinitialisation : **bandeau de succès vert** avec un message neutre et un lien « Retour à la connexion ». - Réinitialisation effectuée : message de confirmation puis retour au login. -

Pendant le traitement, une **barre de progression** et un libellé de bouton dynamique (« Connexion... », « Création... », « Envoi... ») confirment que l'action est en cours.

2.3 Interface utilisateur (UI)

Les boutons, menus, champs et icônes sont-ils faciles à comprendre ? Oui. L'interface repose sur **Angular Material 3** : chaque écran est une carte (`mat-card`) centrée contenant un formulaire à champs `outline` , un bouton d'action principal plein (`filled`) et des liens secondaires discrets. L'icône « œil » (`visibility / visibility_off`) sur les champs mot de passe est universellement comprise comme « afficher/masquer ».

Les textes et les instructions sont-ils clairs ? Oui, et surtout **contextualisés**. Le champ mot de passe affiche une consigne (`mat-hint`) qui énonce la politique attendue : « Au moins 8 caractères et 3 types parmi : minuscule, majuscule, chiffre, caractère spécial. » L'utilisateur connaît la règle **avant** de se tromper, pas seulement après.

Les éléments importants sont-ils suffisamment visibles ? L'action principale est le seul bouton plein de l'écran, ce qui la rend immédiatement identifiable. Les liens de navigation secondaire (créer un compte, mot de passe oublié) sont présents mais visuellement en retrait, respectant la hiérarchie.

L'interface est-elle cohérente d'un écran à l'autre ? Fortement. Les quatre écrans partagent la **même structure** (carte, titre, sous-titre, éventuel bandeau d'alerte, formulaire, lien de repli). Un utilisateur qui a compris l'écran de connexion navigue sans réapprentissage sur les trois autres. Cette cohérence provient d'une base technique commune (design system, composants partagés `Alert` , `EmptyState` , `Skeleton`).

Les maquettes correspondent-elles à la fonctionnalité développée ? Le rendu implémenté suit les décisions du design system (Material 3 + thèmes clair/sombre). Les écrans réalisés correspondent aux parcours prévus au cahier des charges (UC d'inscription/connexion). *Point à mettre à jour : formaliser des captures d'écran des quatre états dans le dossier de conception (voir §4).*

2.4 Expérience utilisateur (UX)

Le parcours est-il logique et intuitif ? Oui : login au centre, création de compte et récupération à un clic de distance, retour au login toujours possible. La boucle « oubli → e-mail → réinitialisation → login » est fermée et cohérente.

À quel endroit l'utilisateur pourrait-il hésiter ou se sentir perdu ? - Après une demande de réinitialisation, le message est **volontairement neutre** (« Si un compte existe pour cette adresse, un lien a été envoyé »). C'est un choix de sécurité (anti-énumération), mais un utilisateur pressé pourrait douter que « ça a marché ». Le bandeau vert atténue ce doute. - Le lien de réinitialisation est, en développement, **journalisé côté serveur** (aucun e-mail réellement envoyé). Un testeur non averti pourrait attendre un courriel qui n'arrive pas.

Quelles erreurs pourrait-il commettre ? - Saisir un e-mail mal formé → détecté côté client (« Format d'adresse e-mail invalide »). - Choisir un mot de passe trop faible → refusé côté client **et** côté serveur (double barrière). - À la réinitialisation, saisir deux mots de passe différents → bandeau d'avertissement « Les deux mots de passe ne correspondent pas ». - Ouvrir un lien de réinitialisation incomplet (sans jeton) → l'écran détecte l'absence de jeton et propose de « Demander un nouveau lien » plutôt que d'afficher un formulaire inutilisable.

Les messages d'erreur expliquent-ils le problème et comment le corriger ? Oui. La traduction des erreurs serveur est centralisée : chaque code HTTP produit un message actionnable — 401 « Adresse e-mail ou mot de passe incorrect », 409 « Cette adresse e-mail est déjà utilisée », 423 « Compte temporairement verrouillé... Réessayez plus tard », 0 « Impossible de joindre le serveur. Vérifiez votre connexion. » L'utilisateur sait **quoi faire**, pas seulement que « ça a échoué ».

L'utilisateur peut-il facilement revenir en arrière ou modifier son action ? Oui : chaque écran secondaire offre un lien de retour au login, et la navigation par le routeur préserve l'historique du navigateur. Les champs restent éditables tant que la soumission n'est pas partie.

La fonctionnalité répond-elle réellement à son besoin ? Oui. Elle délivre un accès sécurisé, une inscription immédiate, et un chemin de récupération complet. Le **verrouillage temporaire** (5 tentatives échouées → blocage 15 minutes) protège contre les attaques par force brute sans punir durablement un utilisateur légitime distrait : le compteur se remet à zéro après une connexion réussie ou une réinitialisation.

2.5 Accessibilité et inclusion

Le texte est-il lisible ? Le contraste est-il suffisant ? L'usage de Material 3 avec ses rôles de couleur, et la prise en charge du **mode sombre**, garantissent des contrastes conformes dans les deux thèmes. Les tailles de police suivent l'échelle typographique du design system.

Les formulaires sont-ils correctement étiquetés ? Oui. Chaque champ possède un `mat-label` associé ; les cartes sont reliées à leur titre par `aria-labelledby`. Les champs déclarent des `autocomplete` pertinents (`email`, `current-password`, `new-password`, `given-name`, `family-name`), ce qui aide les gestionnaires de mots de passe et l'auto-remplissage.

La solution dépend-elle uniquement de la couleur pour transmettre une information ? Non. Les erreurs sont portées par du **texte explicite** (`mat-error`, bandeaux `Alert` avec `role="alert"` annoncé aux lecteurs d'écran), pas seulement par une couleur rouge. Le bouton « afficher/masquer » expose son état via `aria-pressed` et un `aria-label` dynamique, et pas uniquement via l'icône.

La fonctionnalité peut-elle être utilisée sur différents appareils ? Oui : la carte centrée et responsive s'adapte du mobile au poste de bureau. Les champs pleine largeur et les cibles tactiles des boutons conviennent au tactile.

Quelles améliorations rendraient l'expérience plus accessible ? - Ajouter un **indicateur de robustesse** du mot de passe en temps réel (au-delà de la simple consigne). - Gérer explicitement le **focus** après soumission ou apparition d'un bandeau d'erreur, pour que les lecteurs d'écran soient portés directement sur le message. - Prévoir une aide au **remplissage/annonce** des délais de verrouillage (« réessayez dans X minutes »).

2.6 Améliorations identifiées

L'analyse fait ressortir des points forts (cohérence, messages actionnables, sécurité soignée) mais aussi des pistes d'amélioration côté expérience :

1. **Doute après la demande de réinitialisation** : le message neutre protège la vie privée mais peut inquiéter. → Ajouter une ligne d'explication (« Vérifiez votre boîte de réception et vos spams ») et, en environnement de test, un mode de récupération plus visible du lien.
2. **Absence d'indicateur de force du mot de passe** : la règle est énoncée mais l'utilisateur ne mesure pas sa progression. → Ajouter une jauge de robustesse.
3. **Verrouillage peu explicite sur le délai** : le message dit « Réessayez plus tard » sans durée. → Afficher le temps restant si l'API le fournit.
4. **Gestion du focus / lecteurs d'écran** : les bandeaux d'erreur sont annoncés, mais le focus n'est pas déplacé. → Déplacer le focus sur le premier message d'erreur.
5. **Traçabilité maquettes ↔ écrans** : les captures des quatre états ne sont pas encore versionnées dans le dossier de conception. → Ajouter les captures et lier au cahier des charges.

3. Points forts à conserver

- **Cohérence visuelle et structurelle** des quatre écrans : un seul modèle mental à acquérir.
- **Sécurité pensée pour l'utilisateur ET contre l'attaquant** : double validation du mot de passe (client/serveur), verrouillage temporaire non punitif, réponses neutres anti-énumération, jeton de réinitialisation à usage unique et à durée limitée.
- **Messages d'erreur actionnables** centralisés et traduits, y compris le cas « serveur injoignable ».
- **Accessibilité de base solide** : étiquettes, `aria-*`, information non portée uniquement par la couleur, autocomplete.
- **Retours d'état clairs** : barre de progression, libellés de bouton dynamiques, redirection comme signal de succès.

4. Améliorations retenues et prochaines actions

#	Amélioration	Pourquoi elle améliore l'expérience	Artefacts à mettre à jour
1	Ligne d'aide sous la confirmation d'oubli	Lève le doute « est-ce que ça a marché ? »	Code (front), maquettes
2	Jauge de robustesse du mot de passe	Guide l'utilisateur en temps réel, réduit les rejets	Code (front), maquettes
3	Afficher le délai restant du verrouillage	Rend le blocage compréhensible et rassurant	Code (front + API), cahier des charges
4	Déplacement du focus sur les erreurs	Accessibilité lecteurs d'écran	Code (front), tests

#	Amélioration	Pourquoi elle améliore l'expérience	Artefacts à mettre à jour
5	Captures des 4 états dans la conception	Traçabilité maquettes ↔ développé	Dossier de conception (docs), Jira

Prochaines actions concrètes : - Créer des sous-tâches Jira pour les améliorations 1 à 4 (rattachées à MEDIPLAN-15/16). - Ajouter les captures d'écran (login, register, forgot, reset, compte verrouillé) au dossier de conception. - Compléter la documentation de tests : les parcours d'authentification disposent déjà de tests (specs de composants et de service front, tests back du verrouillage/réinitialisation) — les recenser dans un tableau « cas couverts ».

5. Conclusion

L'authentification de MediPlan **ne se contente pas de fonctionner** : elle est claire, cohérente et compréhensible pour un utilisateur qui découvre l'application, tout en portant un niveau de sécurité élevé (verrouillage, anti-énumération, politique de mot de passe, jetons à usage unique). Le parcours est court, guidé et réversible ; les erreurs sont expliquées et corrigibles ; l'accessibilité de base est respectée.

Les améliorations retenues portent moins sur des défauts que sur du **raffinement de l'expérience** : lever le doute après la demande de réinitialisation, guider la création du mot de passe, rendre le verrouillage plus explicite, et renforcer l'accessibilité pour les lecteurs d'écran. Ces évolutions, associées à la mise à jour des maquettes et de la documentation de tests, consolideront une fonctionnalité déjà robuste comme une **base de confiance** pour l'ensemble de la plateforme.